تقييم حدود الثقة في MCP Apps

دراسة تجريبية للقدرات التي يديرها المضيف

Evaluating Trust Boundaries in MCP Apps: An Experimental Study of Host-Mediated Capabilities

2026/8

EMIRATES INTERNATIONAL UNIVERSITY

أ.د.ب. مالك ناصر علي الجبري

مبارك وليد الحمادي.
ياسين عبد العزيز الخلاقي
محمد سيف علي الحيمي

1. المقدمة 3
2. الدراسات السابقة 4
2.1 مقارنة مختصرة للأعمال السابقة 5
2.2 الفجوة البحثية 7
3. الغاية والمساهمة 8
3.1 الغاية من البحث 8
3.2 المساهمة المتوقعة 8
4. المشاكل البحثية 8
4.1 المشكلة الرئيسية 8
4.2 المشاكل الفرعية 8
4.3 فرضيات البحث والحل المفترض 9
5. أهمية البحث وأهدافه 9
5.1 أهمية البحث 9
5.2 الهدف العام 9
5.3 الأهداف الفرعية 9
6. المنهجية 10
6.1 نوع الدراسة وتصميمها 10
6.2 بيئة الاختبار ونطاقه 10
6.3 الحل المقترح 10
6.4 خطوات التنفيذ 11
6.5 مصفوفة الاختبار 11
6.6 القياس وتحليل النتائج 11
6.7 الضوابط الأخلاقية والقيود 12
7. تنظيم الوقت 12
8. المراجع 12

1. المقدمة

يسمح بروتوكول Model Context Protocol (MCP) لتطبيقات الذكاء الاصطناعي بالتعامل مع أدوات وموارد خارجية بطريقة موحدة. ويضيف امتداد MCP Apps واجهات تفاعلية يقدمها خادم MCP ويعرضها المضيف داخل بيئة معزولة، بدل الاكتفاء بإرجاع النصوص والبيانات (Hou et al., 2025; Model Context Protocol, 2026b).

يحمي الـsandbox المضيف من الوصول المباشر إلى صفحته وبياناته، لكن واجهة MCP App تستطيع طلب قدرات ينفذها المضيف، مثل فتح رابط، أو إرسال رسالة إلى المحادثة، أو تحديث سياق النموذج. لذلك لا تقتصر الحماية على العزل، بل تعتمد أيضًا على القرارات والسياسات التي يطبقها المضيف على هذه الطلبات (Salomon et al., 2026).

تنبع أهمية الدراسة من أنها تركز على الحد الفاصل بين **ما يمنعه العزل تقنيًا** و**ما يجب أن يضبطه المضيف بسياساته**. وستقدم الدراسة اختبارًا عمليًا لهذا الحد، ثم تقارن بين مضيف ملتزم بالمواصفة والمضيف نفسه بعد إضافة طبقة سياسة محددة؛ بما يساعد على تقليل المخاطر مع المحافظة على الوظائف المشروعة.

2.الدراسات السابقة

ركزت دراسات أمن MCP على مخاطر الخوادم والأدوات، وإدارة الصلاحيات، وحقن الأوامر غير المباشر. وأظهرت أن اتصال النماذج بالأدوات قد يؤدي إلى تنفيذ غير مرغوب أو كشف بيانات إذا لم تضبط الثقة والصلاحيات (Hou et al., 2025; Maloyan & Namiot, 2026; Radosevich & Halloran, 2025). كما قدمت أعمال AgentDojo وAgentBound أساليب لاختبار الأمن وفرض حدود التنفيذ، لكنها لم تركز على رسائل واجهة MCP App إلى المضيف (Bühler et al., 2026; Debenedetti et al., 2024).

أما مواصفة MCP Apps وSEP-1865 فتحددان العزل وCSP ورؤية الأدوات والقنوات التي يديرها المضيف، لكنهما تقدمان متطلبات تصميم لا مقارنة تجريبية لطبقة تشديد إضافية (Model Context Protocol, 2026b; Salomon et al., 2026).

2.1مقارنة مختصرة للأعمال السابقة

العنوان	الباحثون	السنة	المميزات	العيوب والفجوات
MCP Apps Specification و-SEP 1865	Model Context Protocol؛ Salomon وآخرون	2026	يحددان البنية الرسمية ونموذج التهديد والضوابط	لا يقدمان مقارنة تجريبية قبل سياسة مضيف إضافية وبعدها
Breaking the Protocol	Maloyan وNamiot	2026	تحليل للمواصفة وتجارب على الحقن والثقة	يركز على MCP الأساسي لا القنوات التفاعلية
AgentBound	Bühler وآخرون	2026	يفرض سياسات على تنفيذ خوادم MCP	يعالج مستوى النظام لا رسائل الواجهة
Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions	Hou وآخرون	2025	تصنيف واسع لمخاطر MCP ودورة حياة الخادم	لا يركز على واجهات MCP Apps وقرارات المضيف
MCP Safety Audit	Radosevich وHalloran	2025	تدقيق عملي لمخاطر خوادم وأدوات MCP	لا يختبر الحد بين واجهة MCP App والمضيف
AgentDojo	Debenedetti وآخرون	2024	يقيس الأمن مع الحفاظ على العمل المشروع	بيئة عامة للوكلاء وليست لمضيف MCP Apps
Not What You've Signed Up For	Greshake وآخرون	2023	يوضح خطر حقن الأوامر غير المباشر	ليس مخصصًا لـMCP Apps

2.2الفجوة البحثية

في حدود المصادر التي راجعناها، ركزت الدراسات السابقة على أمن خوادم وأدوات MCP، أو حقن الأوامر وعزل الوكلاء. ولم نجد دراسة تجريبية مركزة تقارن بين مضيف MCP Apps ملتزم بالمواصفة والمضيف نفسه بعد تفعيل سياسة إضافية للتحكم في القدرات التي يديرها المضيف، مع قياس الأمن والحفاظ على الوظائف والأداء. يعالج البحث هذه الفجوة ببناء بيئة اختبار قابلة للتكرار ونموذج أولي صغير لطبقة السياسة.

3.الغاية والمساهمة

3.1الغاية من البحث

قياس حدود الحماية في MCP Apps عمليًا، وتحديد الفرق بين متطلبات العزل الإلزامية والقرارات التي تعتمد على سياسة المضيف، ثم اختبار حل أولي يقلل إساءة استخدام القنوات المسموحة.

3.2المساهمة المتوقعة

- مجموعة اختبارات قابلة للتكرار تفصل بين **اختبارات امتثال المواصفة** و**اختبارات المخاطر المتبقية**.
- نموذج أولي لطبقة سياسة على جانب المضيف تتحكم في الروابط والرسائل وتحديث سياق النموذج وتوضح مصدر الواجهة.
- مقارنة قبل تفعيل الطبقة وبعدها من حيث الأمن، واستمرار الوظائف المشروعة، وزمن المعالجة.

4.المشاكل البحثية

4.1المشكلة الرئيسية

تعزل MCP Apps الواجهة عن المضيف، لكنها تسمح لها بطلب عمليات ينفذها المضيف. ولا يوجد في الأدبيات التي راجعناها تقييم تجريبي بسيط يوضح ما تمنعه المواصفة إلزاميًا، وما قد يبقى ممكنًا عبر القنوات المسموحة، ومدى فاعلية سياسة مضيف إضافية في تقليل هذا الخطر.

4.2المشاكل الفرعية

- **SP1:** الحاجة إلى التحقق عمليًا من التزام المضيف بحدود CSP ورؤية الأدوات والموارد.
- **SP2:** احتمال إساءة استخدام القنوات المسموحة مثل `ui/open-link` و`ui/message` و`ui/update-model-context` من دون كسر الـsandbox.
- **SP3:** الحاجة إلى معرفة هل تقلل طبقة سياسة إضافية السلوك غير المرغوب من دون تعطيل العمل المشروع أو إضافة عبء زمني كبير.

4.3فرضيات البحث والحل المفترض

المشكلة	الفرضية القابلة للاختبار
SP1	H1: سيرفض المضيف الملتزم بالمواصفة جميع حالات الاختبار المخالفة لـCSP ورؤية الأدوات والموارد، وسيسمح بحالات الامتثال المشروعة.
SP2	H2: ستقلل طبقة السياسة المقترحة عدد الإجراءات الحساسة المنفذة دون موافقة، وتمنع انتقال القيمة الاصطناعية عبر قناة غير معتمدة، مقارنة بخط الأساس.
SP3	H3: ستحافظ الطبقة على نجاح جميع حالات التحكم المشروعة المحددة مسبقًا، ولن يتجاوز وسيط العبء الإضافي لمعالجة الطلب محليًا 20 مللي ثانية.

الحل المفترض: طبقة داخل المضيف تعترض الطلبات الحساسة قبل تنفيذها، وتطبق قائمة سماح للروابط، وموافقة صريحة، وإظهار مصدر الواجهة، وحدودًا للحجم ومعدل الطلبات، وسجل تدقيق. تقبل الفرضيات أو ترفض وفق النتائج الفعلية، ولا تفترض الدراسة نجاح الحل مسبقًا.

5.أهمية البحث وأهدافه

5.1أهمية البحث

يوضح البحث مسؤولية المضيف عند التعامل مع واجهة يقدمها خادم غير موثوق، ويمنع الخلط بين حماية الـsandbox وحماية سياسات المضيف. كما يقدم اختبارًا وحلًا أوليًا يمكن لمطوري مضيفات MCP إعادة استخدامهما.

5.2الهدف العام

تقييم حدود الثقة في MCP Apps وبناء طبقة سياسة صغيرة على جانب المضيف وقياس أثرها تجريبيًا.

5.3الأهداف الفرعية

- استخراج المتطلبات الأمنية الإلزامية والقنوات التي تعتمد على سياسة المضيف.
- بناء مختبر محلي وتنفيذ خط أساس موحد وسيناريوهات قابلة للتكرار.
- تنفيذ طبقة السياسة المقترحة وتشغيل السيناريوهات نفسها بعد تفعيلها.
- مقارنة الأمن والوظائف والأداء وقبول الفرضيات أو رفضها وفق النتائج.

6.المنهجية

6.1نوع الدراسة وتصميمها

تستخدم الدراسة **منهجًا تجريبيًا تطبيقيًا** داخل مختبر محلي معزول. وتنفذ الحالات نفسها في مجموعتين:

- **Baseline:** مضيف اختبار يطبق متطلبات MUST في مواصفة MCP Apps، دون طبقة السياسة الإضافية.
- **Treatment:** المضيف نفسه والبيئة نفسها، مع تفعيل الطبقة المقترحة فقط.

المتغير المستقل هو حالة الطبقة (معطلة/مفعلة)، والمتغيرات التابعة هي قرارات السماح والرفض، وتنفيذ الإجراءات دون موافقة، ووصول البيانات الاصطناعية، ونجاح الوظائف المشروعة، وزمن المعالجة.

6.2بيئة الاختبار ونطاقه

- جهاز Linux واحد وبيئة محلية معزولة.
- مضيف اختبار واحد مبني على basic-host وAppBridge من مشروع Model) ext-apps (Context Protocol, 2026a).
- خادم MCP محلي، وواجهة مشروعة، وواجهة اختبار غير موثوقة.
- أدوات وموارد وهمية، وخادم استقبال محلي، وقيمة اختبار مثل SYNTHETIC_SECRET_001.
- سجل موحد لرسائل JSON-RPC وقرارات السياسة والأزمنة.

يفترض البحث أن المهاجم يتحكم في خادم MCP والواجهة، لكنه لا يملك وصولًا مباشرًا إلى جهاز المستخدم. ولا تشمل الدراسة كسر المتصفح أو الهروب من الـsandbox أو إجراء تجربة تصيد على أشخاص حقيقيين.

6.3الحل المقترح

تعترض طبقة السياسة رسائل الواجهة قبل تنفيذها، وتطبق أربع قواعد:

1. **الروابط:** السماح بـhttps فقط، والتحقق من النطاق والمسار، وطلب الموافقة قبل فتح رابط خارجي.
2. **الرسائل والسياق:** طلب الموافقة على ui/message وui/update-model-context، وإظهار المصدر، وتحديد الحجم ومعدل الطلبات.
3. **حد الثقة المرئي:** إضافة علامة ثابتة حول الواجهة توضح أنها مقدمة من خادم MCP خارجي.
4. **التدقيق:** تسجيل المصدر ونوع الطلب والقرار وسببه وزمن المعالجة دون تخزين بيانات حساسة.

تظل اختبارات CSP ورؤية الأدوات جزءًا من امتثال خط الأساس للمواصفة، وليست إسهامًا جديدًا للطبقة.

6.4خطوات التنفيذ

1. تشغيل المثال الرسمي والتحقق من عرض واجهة مشروعة واستدعاء أداة مسموحة.
2. بناء الخادم المحلي والواجهتين والأدوات والموارد الوهمية وخادم الاستقبال.
3. تثبيت حالات الاختبار وتشغيلها في Baseline وتسجيل النتائج.
4. تنفيذ طبقة السياسة كوحدة يمكن تشغيلها وإيقافها.
5. تشغيل الحالات نفسها في Treatment بالإعدادات والبيانات نفسها.

6. مقارنة النتائج واختبار H1 وH2 وH3الاستنتاجات وكتابة

6.5 مصفوفة الاختبار

الاختبار	Baseline المتوقع	Treatment المتوقع	المقياس
أداة مشروعة ذات وصول app	سماح	سماح	الحفاظ على الوظيفة
أداة غير ظاهرة للتطبيق	رفض	رفض	امتثال المواصفة
اتصال إلى نطاق غير معلن في CSP	رفض	رفض	امتثال CSP
فتح رابط خارجي	يرصد ويسجل السلوك الافتراضي للمضيف: سماح أو رفض أو طلب موافقة	موافقة ثم سماح/رفض	التنفيذ دون موافقة
ui/message أو تحديث السياق	يرصد ويسجل السلوك الافتراضي للمضيف: سماح أو رفض أو طلب موافقة	موافقة وإظهار المصدر	سلامة القناة
واجهة تشبه المضيف	تعرض داخل العزل	تظهر معها علامة مصدر ثابتة	وضوح حد الثقة
عملية مشروعة محددة مسبقًا	نجاح	نجاح	الحجب الخاطئ

6.6القياس وتحليل النتائج

- عدد اختبارات الامتثال الناجحة من الإجمالي.
- عدد الطلبات الحساسة المنفذة دون موافقة قبل الطبقة وبعدها.
- نجاح أو فشل انتقال القيمة الاصطناعية في كل قناة.
- نسبة العمليات المشروعة الناجحة، وعدد العمليات المحجوبة خطأ.
- اكتمال سجل التدقيق ومتوسط ووسيط وزمن المعالجة عند الشريحة المئوية 95.

تشغل كل حالة وظيفية خمس مرات في كل مجموعة. ويكرر قياس الأداء 30 مرة بعد خمس عمليات إحماء لا تدخل في الحساب. تعرض النتائج بالأعداد والنسب المئوية والمللي ثانية، ثم تقارن بالنتائج المتوقعة في H1–H3 لتحديد قبول كل فرضية أو رفضها. وتمثل 20 مللي ثانية عتبة تشغيلية أولية حددها الباحثون لتقييم النموذج داخل المختبر، وليست حدًا معياريًا في مواصفة MCP Apps.

6.7الضوابط الأخلاقية والقيود

تجرى جميع التجارب محليًا باستخدام بيانات وحسابات اصطناعية، ولا تستهدف خدمات عامة أو مستخدمين حقيقيين. تقتصر النتائج على مضيف واحد وثلاث فئات من القنوات، ولذلك يمثل النموذج إثبات فكرة وليس منتجًا أمنيًا مكتملًا.

7. تنظيم الوقت

مدة تنفيذ البحث **أربعة أسابيع (شهر واحد)**:

الفترة	العمل الرئيسي	المخرج	التكلفة المباشرة المتوقعة
الأسبوع الأول	مراجعة المواصفة، تشغيل المثال الرسمي، وتثبيت الحالات	مختبر يعمل وخطة اختبار ثابتة	0
الأسبوع الثالث	بناء الواجهتين وتشغيل Baseline	نتائج خط الأساس	0
الأسبوع الخامس	تنفيذ طبقة السياسة وتشغيل Treatment	نتائج ما بعد الحل	0
الأسبوع السادس	تحليل النتائج واختبار الفرضيات وكتابة التقرير	التقرير النهائي	0

لا توجد تكلفة مباشرة متوقعة؛ لأن الجهاز متاح والأدوات مفتوحة المصدر والتجارب محلية. وإذا ظهرت تكلفة طارئة فستوثق في التقرير الفعلي.

8. المراجع

Bühler, C., Biagiola, M., Di Grazia, L., & Salvaneschi, G. (2026). AgentBound: Securing execution boundaries of AI agents. *Proceedings of the 34th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. https://doi.org/10.1145/3808103

Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., & Tramèr, F. (2024). AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses in LLM agents. *NeurIPS 2024 Datasets and Benchmarks Track*. https://arxiv.org/abs/2406.13352

Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*. https://arxiv.org/abs/2302.12173

Hou, X., Zhao, Y., Wang, S., & Wang, H. (2025). *Model Context Protocol (MCP): Landscape, security threats, and future research directions*. arXiv:2503.23278. https://arxiv.org/abs/2503.23278

Maloyan, N., & Namiot, D. (2026). *Breaking the protocol: Security analysis of the Model Context Protocol specification and prompt injection vulnerabilities in tool-integrated LLM agents*. arXiv:2601.17549. https://arxiv.org/abs/2601.17549

Model Context Protocol. (2026a). *ext-apps: Specification and SDK for the MCP Apps extension* [Source code]. https://github.com/modelcontextprotocol/ext-apps

Model Context Protocol. (2026b). *MCP Apps specification* (revision 2026-01-26). https://github.com/modelcontextprotocol/ext-apps/blob/main/specification/2026-01-26/apps.mdx

Radosevich, B., & Halloran, J. (2025). *MCP safety audit: LLMs with the Model Context Protocol allow major security exploits*. arXiv:2504.03767. https://arxiv.org/abs/2504.03767

Salomon, I., Yosef, L., Chafik, O., Swannack, J., Hefner, J., Pidkuiko, A., Cooper, N., Ashley, B., & Christakis, A. (2026). *SEP-1865: MCP Apps—Interactive user interfaces for MCP*. Model Context Protocol. https://modelcontextprotocol.io/seps/1865-mcp-apps-interactive-user-interfaces-for-mcp